

LAPORAN AUDIT KEAMANAN KIKOST

Audit aplikasi, autentikasi, data, domain, infrastruktur, dan supply chain

Tanggal audit	24 Agustus 2026 (Asia/Jakarta)
Jenis	Point-in-time, read-only assessment
Cakupan	Frontend, backend, API publik, domain, TLS, DNS, container, dependency
Frontend	Production @ 81488f0c3674
Backend	HEAD @ 70f17e46dfb5 + perubahan Task Management lokal
Klasifikasi	RAHASIA - penggunaan internal

Kesimpulan singkat

Fondasi keamanan KIKOST cukup baik dan pengujian teknis utama lulus, tetapi sistem belum dapat dinyatakan aman secara keseluruhan sebelum lima temuan risiko tinggi ditangani.

1. Ringkasan Eksekutif

Status keseluruhan: **PERLU REMEDIASI PRIORITAS**. Tidak ditemukan kerentanan dependency yang dikenal atau peringatan statis Rails, namun terdapat risiko tinggi pada akses dokumen sensitif, cakupan cookie autentikasi, jalur login Firebase lama, MFA, dan pemisahan kewenangan finance.

Distribusi temuan

Level	Jumlah	Makna
Kritis	0	Tidak ada temuan yang menunjukkan kompromi aktif atau pengambilalihan langsung tanpa prasyarat.
Tinggi	5	Berpotensi membuka data sensitif atau akun istimewa; perlu dikerjakan sebagai P0/P1.
Sedang	12	Memperluas attack surface atau melemahkan defense-in-depth; selesaikan dalam 30 hari.
Rendah	4	Higiene, hardening, atau reliabilitas terkait keamanan.

Prioritas keputusan

- Lindungi dokumen identitas, selfie, dan bukti pembayaran dengan endpoint download berotorisasi; nonaktifkan route Active Storage publik bawaan.
- Hentikan pemakaian cookie token dengan Domain=.kikost.com atau pisahkan subdomain infrastruktur dari registrable domain aplikasi.
- Hapus login password Firebase lama dan jadikan backend Rails satu-satunya jalur password login.
- Aktifkan MFA untuk admin/finance dan pisahkan hak finance dari admin penuh.
- Dalam 30 hari: sanitasi CSV, konsistenkan validasi upload, proteksi branch, upgrade Node, dan jalankan container backend non-root.

Hal yang sudah kuat

- Test backend 152 runs / 989 assertions lulus; frontend production build dan TypeScript lulus.
- Brakeman, Bundler Audit, dan npm audit tidak menemukan isu dependency atau warning aplikasi.
- HTTPS, TLS modern, CORS allowlist, rate limiting, session rotation, password policy, dan policy Task Management sudah diterapkan.
- Port database/cache tidak terbuka ke internet pada pemeriksaan eksternal.

2. Cakupan dan Metodologi

Audit dilakukan tanpa mengubah state produksi. Pemeriksaan menggabungkan review kode dan konfigurasi, static analysis, dependency audit, pengujian otomatis, serta observasi endpoint/domain publik.

Cakupan

Area	Yang diperiksa
Frontend	Next.js routing/proxy, autentikasi, cookie, role guard, CSP/header, Docker, dependency, build.
Backend	Rails model/controller/service/policy/presenter, session, password reset, upload, export, audit log, Task Management.
Data & API	Authorization/IDOR, scoping property-unit, dokumen sensitif, refresh/logout, rate limit, CORS.
Infrastruktur	Domain, redirect HTTPS, TLS, DNS/email records, port publik, Coolify login surface, container hardening.
Supply chain	npm/gem advisory, Git hygiene, branch protection publik, CI, image/runtime version.

Metode dan bukti

- Review manual alur autentikasi, policy role, lifecycle maintenance/task, file delivery, dan export.
- Eksekusi Brakeman 8.0.6, Bundler Audit dengan advisory DB terbaru 23 Agustus 2026, npm audit, test backend, lint, dan production build.
- Permintaan HTTP langsung ke domain dan API untuk security header, redirect, CORS, unauthorized response, endpoint legacy, dan cookie.
- Handshake TLS dan query DNS untuk versi protokol, sertifikat, CAA, SPF, DKIM, DMARC, DNSKEY, dan DS.
- Pemeriksaan port dari luar untuk SSH, HTTP(S), database, cache, dan port aplikasi umum.

Batasan: audit ini adalah snapshot pada 24 Agustus 2026, bukan jaminan bebas risiko. Konfigurasi internal Coolify, firewall host, off-site backup, GitHub MFA, backend branch protection, dan rotasi secret tidak dapat diverifikasi tanpa sesi/otoritas admin terkait.

Skala risiko

Level	Kriteria ringkas	Target
Tinggi	Kerahasiaan data sensitif, akun privileged, atau trust boundary dapat terdampak.	P0/P1: 0-7 hari
Sedang	Eksplorasi memerlukan kondisi tambahan, tetapi defense-in-depth atau cakupan dampak melemah.	P1/P2: <=30 hari
Rendah	Hardening, higiene, dan reliabilitas yang menurunkan risiko kumulatif.	P2/P3: <=90 hari

3. Temuan Risiko Tinggi

TINGGI H-01 Dokumen sensitif memakai URL Active Storage publik permanen Terbuka	
Bukti	Model/presenter user menghasilkan rails_blob_path untuk profile picture, identity document, dan selfie. Route Active Storage default tidak dinonaktifkan. Uji lokal menunjukkan URL bertanda tangan dapat diakses tanpa sesi dan menghasilkan redirect ke file.
Dampak	Siapa pun yang memperoleh URL dapat mengakses dokumen sampai blob dihapus atau key dirotasi. Ini mencakup NIK/identitas, selfie, dan potensi bukti pembayaran.
Rekomendasi	Buat controller download yang mewajibkan autentikasi + policy per resource. Set config.active_storage.draw_routes = false, gunakan route khusus, batasi caching, dan lakukan migrasi/rotasi URL lama. Uji tenant/owner/admin lintas properti.

TINGGI H-02 Cookie access/refresh token berlaku untuk seluruh subdomain Terbuka	
Bukti	Backend dan frontend menetapkan Domain=.kikost.com. Respons live app.kikost.com juga mengirim token dengan domain tersebut. Cookie ikut terkirim ke setiap subdomain, termasuk coolify.kikost.com yang merupakan permukaan infrastruktur berbeda.
Dampak	Kompromi atau salah konfigurasi satu subdomain memperbesar peluang pencurian, overwrite, session fixation, atau kebocoran token aplikasi utama.
Rekomendasi	Gunakan host-only cookie melalui arsitektur same-origin/BFF. Minimal, pindahkan Coolify ke registrable domain terpisah dan jangan bagikan cookie autentikasi ke subdomain infrastruktur. Pertahankan Secure, HttpOnly, SameSite, rotasi refresh, dan session_version.

3. Temuan Risiko Tinggi (lanjutan)

TINGGI H-03 Login masih mengirim password ke Firebase yang sudah dinonaktifkan		Terbuka
Bukti	LoginForm menjalankan loginWithFirebaseEmail(email, password) lebih dulu dan hanya fallback ke backend pada user-not-found. Endpoint sinkronisasi legacy backend sudah mengembalikan 410 Gone pada kode dan produksi.	
Dampak	Password pengguna tetap diproses pihak/jalur legacy yang tidak lagi diperlukan. Hal ini memperluas credential exposure dan dapat menyebabkan login inkonsisten untuk akun Firebase lama.	
Rekomendasi	Hapus Firebase-first password login. Kirim password hanya ke endpoint Rails. Pertahankan provider eksternal hanya jika resmi didukung, terdokumentasi, dan memiliki migrasi akun yang jelas. Cabut key/config Firebase yang tidak lagi dipakai setelah monitoring.	

TINGGI H-04 Belum ada MFA untuk akun privileged KIKOST		Terbuka
Bukti	Tidak ditemukan TOTP, WebAuthn/passkey, recovery code, maupun enforcement MFA pada admin/finance/owner. Proteksi saat ini mengandalkan password, rate limiting, dan session controls.	
Dampak	Phishing, credential stuffing yang lolos, atau reuse password dapat langsung memberi akses administratif dan data lintas akun.	
Rekomendasi	Implementasikan MFA wajib untuk admin dan finance, lalu owner. Prioritaskan WebAuthn/passkey atau TOTP, sediakan recovery code sekali pakai, step-up authentication untuk aksi sensitif, dan activity log enrollment/reset.	

TINGGI H-05 Role finance diperlakukan sebagai admin penuh		Terbuka
Bukti	User#admin? bernilai true untuk role admin dan finance. Semua policy/check yang memakai admin? memberi finance akses luas, termasuk data pribadi, dokumen identitas, maintenance, komunikasi, dan operasi non-keuangan.	
Dampak	Pelanggaran least privilege memperbesar blast radius akun finance. Penilaian ini bersifat kondisional: bila finance memang dipercaya setara super-admin, keputusan itu harus dinyatakan dan diterima secara formal.	
Rekomendasi	Pisahkan predicate role exact dan policy berbasis capability. Batasi finance pada billing/payment/report relevan, masking PII yang tidak perlu, serta tambahkan matrix test deny-by-default untuk seluruh endpoint sensitif.	

4. Temuan Risiko Sedang

SEDANG		M-01 CSV export rentan formula injection	Terbuka
Bukti	Export maintenance dan property memasukkan judul, issue, nama tenant/unit, dan nilai lain langsung ke CSV tanpa netralisasi awalan =, +, -, atau @.		
Dampak	Saat file dibuka di spreadsheet desktop, sel yang dikontrol pengguna dapat dievaluasi sebagai formula dan memicu exfiltration atau social engineering.		
Rekomendasi	Gunakan sanitizer terpusat yang mem-prefix apostrophe pada formula-like cells, pertahankan UTF-8, dan tambahkan test untuk seluruh field serta karakter tab/CR/LF.		

SEDANG		M-02 Validasi upload belum konsisten berbasis konten	Terbuka
Bukti	Upload maintenance melakukan signature check dan decode libvips. Namun identity/selfie/profile, media property/unit, dan receipt tertentu masih bergantung pada content_type client atau pemeriksaan prefix terbatas; analyzer produksi dinonaktifkan.		
Dampak	File polyglot, file rusak, decompression bomb, atau konten tidak sesuai tipe dapat tersimpan dan diproses downstream.		
Rekomendasi	Standarkan pipeline: magic-byte/Marcel, decode image fail-closed, pixel/dimension limits, parser PDF aman, nama acak, count/size limits, dan malware scanning untuk dokumen berisiko. Jangan menandai analyzed secara manual tanpa verifikasi.		

SEDANG		M-03 Route staff tidak dilindungi proxy server-side	Terbuka
Bukti	Proxy frontend tidak memasukkan technician/housekeeper, prefix /staff, atau required role staff. Uji tanpa login ke /staff/tasks mendapat 200, sedangkan /admin mendapat redirect. Client RoleGuard dan API policy tetap menahan data.		
Dampak	Tidak terlihat kebocoran data langsung, tetapi defense-in-depth dan perilaku routing autentikasi tidak konsisten; halaman shell staff bisa diakses publik.		
Rekomendasi	Tambahkan staff roles dan /staff ke matcher/proxy, canonical redirect, serta test SSR/middleware untuk unauthenticated, wrong-role, dan valid staff.		

4. Temuan Risiko Sedang (lanjutan)

SEDANG M-04 Content Security Policy masih mengizinkan unsafe-inline		Terbuka
Bukti	CSP produksi mengandung script-src 'unsafe-inline' dan style-src 'unsafe-inline'. Tidak ditemukan dangerouslySetInnerHTML, eval, new Function, atau document.write pada scan kode.	
Dampak	Jika injection HTML terjadi, CSP kurang efektif menahan eksekusi inline script/style.	
Rekomendasi	Migrasikan ke nonce/hash berbasis request untuk script, evaluasi style nonce, lalu hapus unsafe-inline secara bertahap dengan CSP Report-Only dan monitoring violation.	

SEDANG M-05 Dashboard Coolify belum memiliki header browser utama		Terbuka
Bukti	HTTPS dan secure session cookie aktif, registrasi ditutup. Namun respons publik tidak menunjukkan HSTS, CSP, atau X-Frame-Options/frame-ancestors; header Server juga mengekspos nginx.	
Dampak	Meningkatkan risiko clickjacking dan melemahkan mitigasi browser pada panel infrastruktur bernilai tinggi.	
Rekomendasi	Tambahkan HSTS setelah validasi subdomain, frame-ancestors 'none', CSP ketat, Referrer-Policy, dan hapus version disclosure. Batasi akses panel dengan VPN/allowlist bila operasional memungkinkan.	

SEDANG M-06 Frontend container masih menggunakan Node.js 20 yang EOL		Terbuka
Bukti	Dockerfile frontend memakai node:20-alpine. Node.js 20 mencapai end-of-life pada 24 Maret 2026; Next.js 16 membutuhkan minimal Node 20.9 sehingga Node 24 LTS kompatibel secara versi minimum.	
Dampak	Runtime EOL tidak lagi menerima patch keamanan upstream reguler.	
Rekomendasi	Upgrade ke Node 24 LTS, jalankan build/regression test, pin image digest, dan aktifkan pembaruan image terjadwal serta vulnerability scanning di CI.	

4. Temuan Risiko Sedang (lanjutan)

SEDANG	M-07 Container backend berjalan sebagai root	Terbuka
Bukti	Dockerfile backend tidak menetapkan USER non-root. Frontend sudah menjalankan user nextjs non-root.	
Dampak	Jika aplikasi atau dependency dieksploitasi, proses memiliki privilege lebih tinggi di dalam container dan dampak salah konfigurasi mount/capability membesar.	
Rekomendasi	Buat user aplikasi non-root, perbaiki ownership directory runtime, drop Linux capabilities, gunakan read-only root filesystem bila kompatibel, dan uji migration/storage/logging.	

SEDANG	M-08 Branch Production frontend publik belum diproteksi dan CI security tidak tersedia	Terbuka
Bukti	GitHub API menunjukkan protected=false pada branch Production. Repository tidak memiliki workflow .github dan konfigurasi Dependabot. Backend private tidak dapat diverifikasi.	
Dampak	Perubahan dapat masuk tanpa review/check wajib dan regression/security issue lebih mudah lolos ke deployment.	
Rekomendasi	Aktifkan branch protection/ruleset, PR review, required build/test, secret scanning, Dependabot/Renovate, CodeQL, signed commits bila sesuai, dan audit hal serupa pada backend.	

SEDANG	M-09 Respons permintaan OTP dapat membantu enumerasi role akun	Terbuka
Bukti	Service mengembalikan delivery_status=queued untuk akun non-tenant/inaktif, sedangkan pengiriman produksi yang nyata dapat menghasilkan sent, walau pesan utama dibuat generik.	
Dampak	Penyerang dapat membedakan email tenant aktif dari akun privileged/non-tenant dan meningkatkan kualitas phishing.	
Rekomendasi	Samakan body, status, timing, dan delivery_status eksternal. Simpan detail delivery hanya di log internal yang terproteksi dan rate-limit berdasarkan IP + identifier.	

4. Temuan Risiko Sedang (lanjutan)

SEDANG		M-10 Logout client tidak selalu dapat menghapus cookie domain	Terbuka
Bukti	Jika request logout backend gagal, fallback JavaScript mencoba menghapus cookie host-only. Cookie token HttpOnly dengan Domain=.kikost.com tidak dapat dihapus JavaScript dan dapat bertahan sampai expiry/revocation.		
Dampak	Pengguna dapat mengira sudah logout ketika sesi masih valid pada kondisi backend/network failure.		
Rekomendasi	Sediakan route logout same-origin/server-side yang selalu meng-expire seluruh variasi cookie domain/path, lalu lakukan revocation backend sebagai best effort. Tampilkan status gagal yang jujur dan pendekkan access-token TTL.		

SEDANG		M-11 DNSSEC belum aktif dan DMARC belum enforcement penuh	Terbuka
Bukti	Tidak ditemukan DS/DNSKEY. DMARC masih p=quarantine; pct=25, meskipun SPF -all, DKIM aktif, CAA Let's Encrypt, dan MX Hostinger sudah baik.		
Dampak	DNS belum memiliki chain-of-trust dan 75% pesan belum terkena kebijakan DMARC quarantine; spoofing resilience belum maksimum.		
Rekomendasi	Aktifkan DNSSEC melalui DNSKEY/DS yang valid. Monitor DMARC aggregate report, naikkan pct bertahap ke 100, lalu p=reject setelah seluruh pengirim sah selaras SPF/DKIM.		

SEDANG		M-12 Off-site backup dan private object storage belum dapat dibuktikan	Terbuka
Bukti	Laporan 21 Agustus mencatat backup database lokal terjadwal, tetapi S3/off-server backup masih pending. Active Storage memakai local storage pada konteks yang diperiksa. Sesi admin Coolify tidak tersedia untuk revalidasi job/restore.		
Dampak	Kegagalan disk/host, ransomware, atau insiden provider dapat memengaruhi data primer dan backup pada fault domain yang sama.		
Rekomendasi	Gunakan bucket privat off-site dengan versioning, encryption, lifecycle/retention, kredensial least-privilege, dan restore drill terjadwal. Dokumentasikan RPO/RTO dan bukti restore terakhir.		

5. Temuan Risiko Rendah

ID	Temuan	Tindakan
L-01	HSTS frontend/API belum includeSubDomains/preload.	Aktifkan setelah semua subdomain dipastikan HTTPS dan pertimbangkan preload secara sadar.
L-02	Mailer reset password menunjuk /auth/reset-password, tetapi route frontend tidak terbangun.	Sediakan route reset yang aman; token tetap one-time, digest, 30 menit, dan tidak masuk log/referrer.
L-03	Server-side refresh frontend mengharapkan token di body, sedangkan backend produksi memakai cookie HttpOnly.	Selaraskan kontrak refresh; jangan pernah expose refresh token di body produksi.
L-04	Repository frontend menyimpan artefak lama screenlog.0 dan paket next-swc tgz sekitar 37 MB.	Hapus melalui perubahan terkontrol, audit history, dan cegah artefak/log ikut commit melalui ignore + CI check.

Temuan rendah tidak menghalangi operasional saat ini, tetapi perlu diselesaikan agar hardening tidak bergantung pada asumsi dan mekanisme fallback yang rapuh.

6. Kontrol yang Sudah Baik dan Hasil Pengujian

Hasil berikut mengurangi risiko dan harus dipertahankan sebagai regression gate.

Kontrol / pengujian	Hasil	Catatan
Backend test suite	LULUS	152 runs, 989 assertions, 0 failures, 0 errors, 0 skips.
Frontend production build	LULUS	Next.js 16.3.1; TypeScript dan build 45 halaman berhasil.
Frontend lint	LULUS*	0 error; 1 warning lama terkait penggunaan img pada HomeHeroCarousel.
Brakeman 8.0.6	LULUS	0 warning dan 0 error pada Rails 8.0.5.1.
Bundler Audit	LULUS	0 vulnerability; advisory database diperbarui 23 Agustus 2026.
npm audit	LULUS	0 vulnerability pada dependency frontend.
CORS live	LULUS	Origin app.kikost.com diizinkan tepat; origin evil tidak mendapat ACAA.
API unauthorized	LULUS	Endpoint user/diagnostic menolak tanpa token dengan 401; legacy sync 410.
Task Management policy	LULUS REVIEW	Tenant/owner/staff/admin scope, transition, checklist, upload, dan activity log divalidasi backend.

Kontrol aplikasi yang terverifikasi

- Password minimal 12 karakter, maksimal 72 byte; reset token disimpan sebagai digest, sekali pakai, dan kedaluwarsa 30 menit.
- Refresh token disimpan sebagai digest, dirotasi, dan session_version mendukung revocation.
- Rate limit tersedia pada login, refresh, reset/change password, OTP email, payment, dan review.
- Maintenance upload memeriksa signature, decode libvips, dimensi, ukuran, jumlah, dan filename UUID.
- Activity log menyimpan aktor/perubahan dan melakukan sanitasi field sensitif.

7. Verifikasi Domain dan Infrastruktur Publik

Objek	Hasil 24 Agustus 2026	Status
kikost.com	HTTPS 200; HTTP redirect ke HTTPS; security header aktif.	Baik
www.kikost.com	Redirect 308 ke canonical domain.	Baik
booking.kikost.com	Redirect 308 ke alur booking.	Baik
app.kikost.com/auth	HTTPS 200; secure cookies; broad Domain=.kikost.com dicatat sebagai H-02.	Perlu perbaikan
API health	200; endpoint protected menolak akses tanpa token.	Baik
coolify.kikost.com	Redirect ke login; registrasi disabled; header hardening belum lengkap.	Perlu hardening
TLS	TLS 1.3; TLS 1.0 ditolak; sertifikat Let's Encrypt valid 15 Agu - 13 Nov 2026.	Baik
Port publik	22, 80, 443 reachable; 5432, 6379, 6001, 6002, 8000, 8080 timeout.	Baik*
Email DNS	SPF -all, DKIM aktif, DMARC quarantine 25%, CAA Let's Encrypt.	Parsial
DNSSEC	DS dan DNSKEY tidak ditemukan.	Belum aktif

Catatan port 22

SSH sengaja tersedia untuk administrasi. Pastikan hanya key authentication, root login dinonaktifkan, allowlist/VPN bila memungkinkan, Fail2ban aktif, dan audit log ditinjau. Konfigurasi internal tersebut berasal dari baseline laporan 21 Agustus dan tidak direvalidasi melalui login pada audit ini.

Catatan Coolify

Halaman login dapat diakses dan registrasi dinonaktifkan. Karena sesi admin tidak tersedia, status MFA akun, dashboard terminal, versi aktual, firewall host, backup job, dan access policy internal tetap berstatus belum diverifikasi.

8. Roadmap Remediasi

Urutan di bawah memprioritaskan pengurangan blast radius dan perlindungan data pribadi.

Prioritas	Target	Pekerjaan	Kriteria selesai
P0	0-72 jam	H-01: proteksi private files; H-02: putus cookie dari semua subdomain; H-03: hentikan Firebase password path.	URL file tanpa sesi menghasilkan 401/404; cookie host-only; hanya Rails menerima password.
P1	<=7 hari	H-04 MFA admin/finance; H-05 least privilege finance; M-01 CSV; M-09 enumerasi; M-10 logout.	Matrix authorization lulus, MFA enforced, export aman, respons auth seragam, logout pasti expire.
P2	<=30 hari	Upload pipeline, staff proxy, CSP nonce, Coolify headers/access, Node 24, backend non-root, branch rules + CI.	Build/test/security scans menjadi required checks; container dan browser hardening terverifikasi.
P3	<=90 hari	DNSSEC, DMARC reject bertahap, off-site backup + restore drill, HSTS subdomain, repo hygiene.	Bukti DS aktif, DMARC 100/reject, restore berhasil sesuai RPO/RTO, artefak lama dibersihkan.

Urutan implementasi teknis P0

Langkah	Dependency / pengaman
1. Private file delivery	Buat policy + endpoint; test lintas role/property; baru nonaktifkan default routes agar tidak memutus akses sah.
2. Cookie boundary	Pilih BFF/same-origin atau isolasi infra domain; siapkan migrasi cookie dan invalidasi sesi lama.
3. Login Rails-only	Pastikan seluruh akun Firebase lama sudah memiliki kredensial/reset path Rails; monitor error lalu cabut konfigurasi lama.
4. Privileged MFA	Enrollment, recovery, reset berotorisasi, step-up, dan audit event sebelum enforcement penuh.
5. Finance policies	Dokumentasikan kebutuhan bisnis, pecah capability, implementasi deny-by-default, dan acceptance test.

9. Checklist Pemilik Sistem

Item berikut memerlukan akun, otoritas, atau keputusan bisnis pemilik sistem. Ini bukan bukti bahwa kontrol tidak ada; statusnya belum dapat diverifikasi dalam audit read-only.

No.	Tindakan	Tujuan	Bukti yang diharapkan
1	Aktifkan MFA akun Coolify.	Melindungi control plane dari account takeover.	Screenshot/enforcement policy + recovery procedure.
2	Nonaktifkan dashboard terminal Coolify bila tidak diperlukan.	Mengurangi jalur eksekusi command dari web panel.	Setting disabled dan uji akses.
3	Aktifkan DNSSEC setelah tersedia DNSKEY/DS.	Menambahkan integritas chain-of-trust DNS.	DS terlihat dari parent zone dan validasi sukses.
4	Tambahkan S3/private object storage untuk backup off-server.	Memisahkan fault domain dan meningkatkan disaster recovery.	Backup terenkripsi + restore drill berhasil.
5	Login GitHub lalu audit MFA dan branch protection.	Melindungi software supply chain.	Org MFA enforced, ruleset, reviews, status checks.
6	Jadwalkan rotasi seluruh production secrets.	Membatasi umur credential yang mungkin terekspos.	Inventory, owner, tanggal rotasi, bukti aplikasi tetap sehat.
7	Naikkan DMARC bertahap hingga p=reject.	Mengurangi spoofing email domain KIKOST.	Aggregate report bersih, pct=100, p=reject.

Jangan melakukan rotasi secret, perubahan DNS, atau enforcement MFA tanpa rollback plan dan monitoring. Setiap tindakan harus memiliki owner dan bukti verifikasi.

Kriteria penutupan audit

- Kelima temuan tinggi memiliki patch, test authorization/security, review, dan bukti deployment.
- Tidak ada URL dokumen sensitif yang dapat digunakan tanpa sesi dan policy aktif.
- Token autentikasi tidak pernah dikirim ke subdomain infrastruktur.
- Admin/finance wajib MFA dan finance tidak memiliki kewenangan di luar kebutuhan bisnis.
- P0/P1 diretest dari sisi kode dan endpoint produksi; bukti disimpan dalam change record.

10. Lampiran Bukti dan Referensi

Referensi kode utama

Area	Lokasi
Private file URLs	backend/app/models/user.rb; backend/app/presenters/user_presenter.rb; config Active Storage
Cookie domain	backend/app/controllers/concerns/auth_session_cookies.rb; frontend/src/proxy.ts
Firebase login	frontend/src/components/auth/LoginForm.tsx; backend legacy_auth_controller.rb
Finance privilege	backend/app/models/user.rb dan seluruh policy/check admin?
CSV export	maintenance_requests_controller.rb; properties/export_service.rb
Upload	user update services; property/unit upload; financial receipt; maintenance attachment service
Staff proxy	frontend/src/proxy.ts dan halaman /staff/tasks
Container	frontend/Dockerfile; backend/Dockerfile; kedua .dockerignore

Referensi otoritatif

- Rails Active Storage Overview - default controllers are publicly accessible and signed URLs are permanent: guides.rubyonrails.org/active_storage_overview.html
- Node.js EOL policy dan release status: nodejs.org/en/about/eol dan [previous releases](#)
- Next.js 16 upgrade guide dan minimum Node.js 20.9: nextjs.org/docs/app/guides/upgrading/version-16
- Ruby branch lifecycle: ruby-lang.org/en/downloads/branches
- Frontend Production branch evidence: [GitHub branch API](#)

Integritas dan interpretasi

Commit hash dicatat agar hasil dapat dikaitkan dengan snapshot yang diperiksa. Backend memiliki perubahan Task Management lokal yang belum menjadi commit pada saat audit. Tidak ada secret aktual yang dicetak ke laporan. Temuan secret-history dibatasi pada pola/metadata untuk mencegah kebocoran ulang.

Kesimpulan: kontrol dasar KIKOST sudah nyata dan test utama lulus. Status aman secara keseluruhan baru layak diberikan setelah H-01 sampai H-05 ditutup dan diretest pada produksi.